



CENTRO DE ESTUDIOS FINANCIEROS

C/ Viriato, 52 y Ponzano, 15 • Telf.: 914 444 920 • Fax: 915 938 861 • 28010 MADRID
C/ Gran de Gracia, 171-175 • Telf: 934 150 988 • Fax: 932 174 018 • 08012 BARCELONA
C/ Alboraya, 23 • Telf.: 963 614 199 • Fax: 963 933 354 • 46010 VALENCIA

CUERPO SUPERIOR DE SISTEMAS Y TECNOLOGÍAS DE LA INFORMACIÓN DE LA ADMINISTRACIÓN DEL ESTADO

T122.- El correo electrónico. Servicios de mensajería. (Directorio se cuenta en el Tema 80)

Actualizado: 09-19-2025

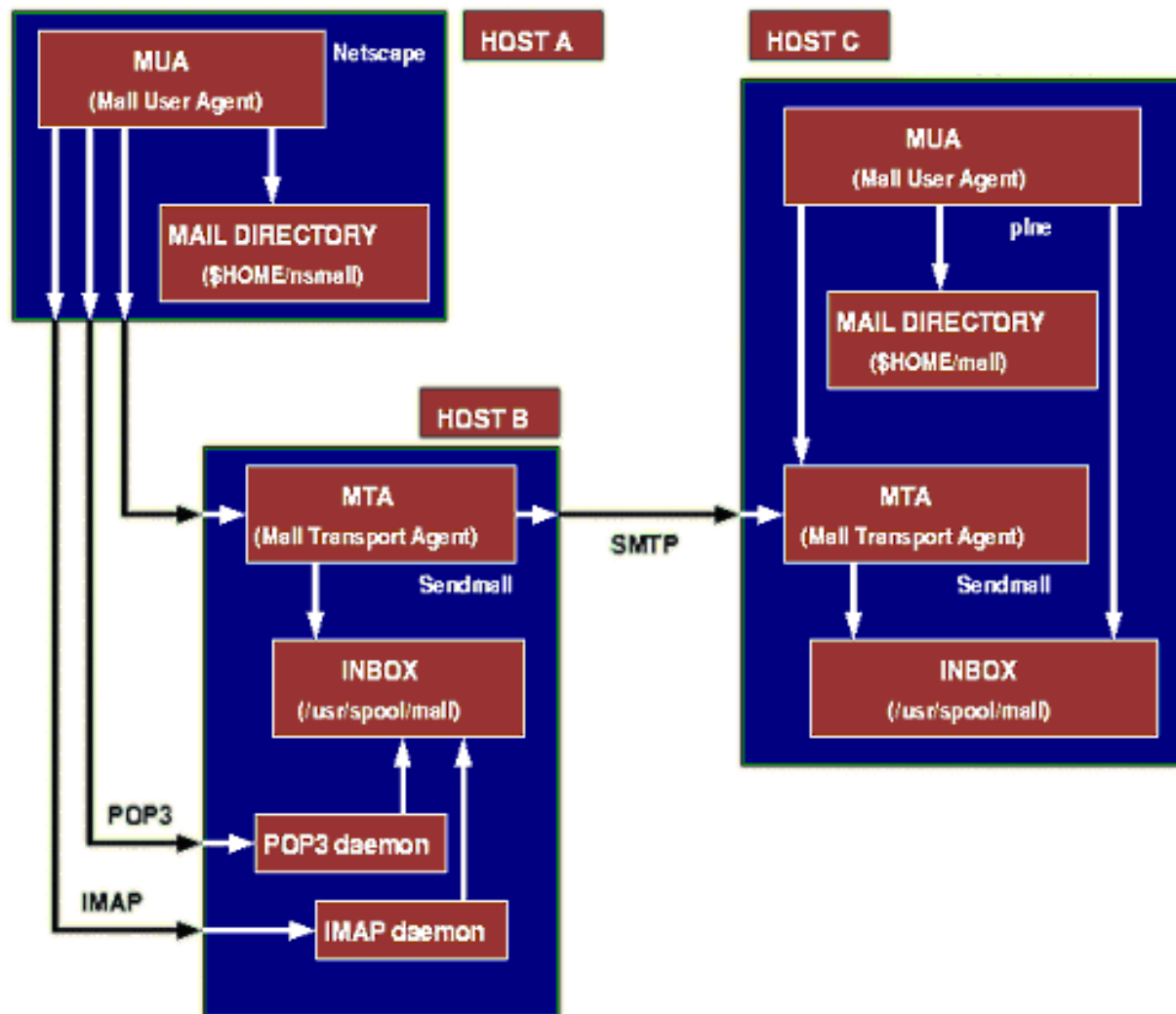
Índice del tema

1	CORREO ELECTRÓNICO.....	2
1.1	CARACTERÍSTICAS.....	2
1.2	COMPONENTES.....	2
2	PROTOCOLOS DE CORREO ELECTRÓNICO.....	3
2.1	X.400.....	3
2.2	SMTP.....	3
2.3	POP3.....	4
2.4	IMAP.....	4
3	SEGURIDAD EN EL CORREO ELECTRÓNICO.....	4
3.1	PGP.....	5
3.2	PEM.....	5
3.3	MOSS.....	6
3.4	S/MIME (SECURE MIME).....	6
3.5	ASPECTOS SOCIALES DEL EMAIL Y SEGURIDAD.....	6
4	ALGUNOS PRODUCTOS.....	8
4.1	PRODUCTOS DE CORREO ELECTRÓNICO.....	8
5	ENLACES.....	8

1 Correo Electrónico

1.1 Características

- Permite el **envío de mensajes** desde un ordenador a otro en cualquier parte del mundo.
- Es **asíncrono**: el emisor envía el mensaje que se almacena en el servidor, y posteriormente el receptor se conecta al servidor y los recoge. **No** se necesita la **conexión simultánea** de ambos participantes.
- Inicialmente **sólo** mensajes **texto** -> Evolución: Mensajes multimedia (MIME)
- **Esquema general:**



1.2 Componentes

- **MUA** (Mail User Agente), es el agente de usuario de correo, el **cliente**
- **MTA** (Mail Transport Agent), es el agente que **transporta** los mensajes a su destino final utilizando una session SMTP. El **MTA** acepta mensajes de otros MUA y otros MTA. En Salida del correo, se puede utilizar un **MSA** (mail submission agent)
- **MDA** (Mail Agent Delivery). Programa encargado de **entregar** el correo al usuario final. (tb. LDA (local delivery agent). Sólo gestiona, no transporta. Funciones: filtrado, respuestas automáticas, etc.
- **DNS server:** Servidor de Resolución de nombres

2 Protocolos de correo electrónico

2.1 X.400

Nombre: **X.400** Message Handling System (X.400 MHS)

Son una serie de recomendaciones de la **CCITT**

Utiliza los servicios de directorio de **X.500**

Exige la pila **OSI** en cliente y servidor

Direccionamiento: formato jerárquico, basado en X.500:

- Pais: c=
- Gestión Administrativa: a= Domain (ADMD)
- Dominio de Administración Privado: p= (PRMD)
- Organización: o=
- Unidades Organizativas: ou=
- Nombre Común: cn=
- ...
- Ej: cn=Tracy Bradley;o=Exchange;p=SW Spectrum;a= ;c=es

Tracy.bradley@exchange. SW Spectrum.es

Completa funcionalidad

Servicios que ofrece:

- **Entrega diferida** (con cancelación previa a la entrega) → RECALL
- **Cuerpo Múltiple** (permite varios documentos adjuntos)
- Posible **destinatario alternativo**
- Notificación de **NO entrega** (ej. si el usuario no existe)
- Entrega a **múltiples** destinatarios
- **Entrega retenida**. A la espera de un evento
- **Caducidad**
- **Reenvío** de mensaje entrantes → (.forward)

Versiones publicadas: X.400(1984) y X.400(1988). Propuestas no muy extendidas de 1993 y 1996

2.2 SMTP

Simple Mail Transfer Protocol (**RFC 821 - 822**) Actualizaciones RFC 2821 (2001) y RFC 5321 (2008).

Funciones

- Transferencia de mensajes entre servidores
- Envío de mensajes desde el usuario al servidor ("servidor de correo saliente")

Estructura de los mensajes:

- **Cabecera**, con campos de: destino, asunto, destinatario, CC, BCC
- **Cuerpo** del mensaje: texto y/o ficheros adjuntos

Forma de envío

- Se establece un **protocolo** entre el SMTP emisor y el SMTP receptor
- Utiliza una conexión **TCP**, puerto estándar asignado **25**
- A cada envío el receptor contesta OK o con un error
- Inicialmente (RFC 822) sólo caracteres de **7bits** -> problemas con 'ñ'
- Solución: **MIME** (Multipurpose Internet Mail Extensions, **RFC 1521**), las cuales se usan en numerosos servicios de Internet, como HTTP

Ej. Parte MIME de un mensaje:

```
MIME-Version: 1.0
-----=_NextPart_000_01C3F630.1AA6ADA0
-Content-Type: image/jpeg; name="1.jpg"
Content-Transfer-Encoding: base64 filename="1.jpg"
```

IANA asigna inicialmente 8 tipos, subtipos, juegos de caracteres (US-ASCII ANSI x3.4 → 1968, ISO-8859-1 → 1987.), etc. (<ftp://ftp.isi.edu/in-notes/iana/assignments/media-types>)

text	multipart	message	application	image	audio	video	model
plain richtext html sgml	mixed voice-message encrypted signed	rfc822 news http	postscript mac-binhex40 pdf zip msword vnd.lotus-1-2-3	jpeg gif tiff png	basic 32kadpcm	mpeg quicktime	vrml mesh iges

- **ESMTP** (Enhanced SMTP) Extensiones a SMTP
 - Diversos usos: Ej: mensajes internacionalizados, autenticación, ahorro ancho banda, etc.
 - Permite al cliente interrogar al servidor sobre las extensiones soportadas.

2.3 POP3

- Post Office Protocol, versión 3
- Interfaz entre un **usuario** y su **servidor** de correo ("servidor de correo entrante")
- Permite **recoger** su correo -> Volcado al ordenador **cliente**
- Utiliza **TCP**, sobre el puerto estándar **110**
- Protocolo extremadamente **sencillo**
- No demasiada funcionalidad

2.4 IMAP

- Internet Message Access Protocol
- Versión actual: **IMAP 4** (Utiliza **TCP**, sobre el puerto estándar **143**)
- Otro protocolo de acceso al servidor de correo desde un cliente
- **Mejora** en gran medida **POP3**
 - Permite **ubicuidad** del cliente
 - **No** exige la **descarga** del correo al cliente
 - Permite la **gestión** de **carpetas** en el servidor

3 Seguridad en el correo electrónico

El análisis de la seguridad se debe realizar desde tres perspectivas:

- desde el punto de vista de la **comunicación electrónica** que se establece **entre los equipos emisor y destinatario** que generalmente se producirá por redes abiertas y expuestas a interceptación por parte de terceras partes no deseadas.
- sobre la **protección de los equipos y servidores físicos que intervienen en la transmisión de mensajes y en el almacenamiento de los mismos**, tanto en los servidores de correo como los equipos finales de usuario.

- **El factor social del correo electrónico.** En este último análisis se tiene en consideración la posibilidad de introducir vulnerabilidades a través de los sistemas de correo electrónico en la organización en forma de código malicioso.

Como con casi todos los servicios de Internet, el correo no contemplaba la seguridad en su diseño inicial. Analizaremos el primer punto desde la perspectiva de los mecanismos de seguridad basados en protocolos o mecanismos pensados para email.

3.1 PGP

- Pretty Good Privacy de Philip R. Zimmermann
- Sistema para encriptación de email más utilizado en el mundo (cada vez menos)
- Utiliza un modelo de firma electrónica donde los propios usuarios establecen la confianza en las claves de los demás
- Utiliza un formato de certificados propios (**PGP Keys**) y ya soporta también certificados **X.509**
- Se envía
 - **Mensaje cifrado** = Mensaje + Firma Digital (Hash) + Certificado (cifrados con clave simétrica)
 - **Sobre** = clave simétrica cifrada con la clave pública del receptor
- Garantiza: identificación, confidencialidad, integridad y no repudio en origen
- Algoritmos: RSA, MD5, IDEA y ZIP
- Ha evolucionado hasta una solución profesional

3.2 PEM

- Privacy Enhanced Mail
- Definido en RFCs 1421 a 1424
- Basado en **estándares**: RFC 822 (cabeceras) y SMTP. Orientado a mensajes de texto
- Es un estándar de internet para las aplicaciones de correo electrónico
- Funcionamiento: codifica el mensaje en formato ASCII -> No interfiere con sistemas de correo existentes (SMTP, X.400, etc.)
- Implementa un **subconjunto** de la funcionalidad de MHS-X.400
- Servicio **extremo a extremo** entre UAs (Agentes de Usuario)
- El emisor y el receptor deben soportar PEM
- Basado en **PKI** y certificados **X.509**
- Servicios de **seguridad**: Autenticación en origen, Confidencialidad, Integridad y No repudio en origen
- **Algoritmos**: DES, RSA y MD5
- **Pasos**:
 1. Codificar el mensaje en ASCII, con CR-LF
 2. Genero información de integridad y autenticidad
 3. Cifrado del mensaje (en Encrypted)
 4. Codificar en formato imprimible (sólo usa 64 caracteres ASCII comunes a todo sistema)
- Permite el envío de tres tipos de mensajes:
 - **Encrypted**: Autenticación en origen, Confidencialidad e Integridad (pasos 1,2,3 y 4)
 - **MIC-Only** (Message Integrity Check). Como encrypted, pero sin confidencialidad (1, 2 y 4)
 - **MIC-Clear**. Como MIC-Only, pero transporta los mensajes de forma que los UA sin capacidad PEM pueden verificar la integridad y el origen del mensaje (1 y 2)

3.3 MOSS

- MIME no proporcionaba servicios de seguridad ->
- Se desarrolla **MOSS** (MIME Object Security Services) en RFC **1848**
- Está basado en **PEM**
- Aplica cifrado y firma digital a los objetos MIME
- Ofrece servicios de seguridad extremo a extremo, de forma transparente a los servidores intermedios
- Diferencia con PEM:
 - En PEM necesitan certificados, en MOSS sólo un par de claves
 - PEM exige primero el cifrado para poder firmar, en MOSS es independiente

3.4 S/MIME (Secure MIME)

- En un mecanismo usable con otros protocolos, como **http**
- **Incorpora servicios de firmas electrónicas y de encriptamiento**
- Desarrollado por **RSA Inc.** (usa, claro está RSA)
 - **formato PKCS #7 para los mensajes**
 - **formato X.509V.3 para los certificados.**
- Propuesto como un estándar de internet moderno
- Facilidad de uso
- No interoperable con MOSS/PEM
- Modos de operación:
 - **S/MIME puede utilizar dos procedimientos para firmas digitales:**

"firmado limpio" (clear signed): interactúa con clientes no S/MIME.

La firma se coloca como un anexo-MIME, codificado en Base64, llamado "smime.p7s", fuera del texto del mensaje.

Algunos "gateways" de correo-e pueden recodificar los anexos MIME alterando en consecuencia el contenido del mensaje.

"firmado opaco" (opaque signing): busca evitar los problemas del formateo en tránsito que realizan algunos "gateways".

Un mensaje se codifica en MIME, en Base-64, en un solo anexo.

Problema: el mensaje será ilegible para usuarios que no utilicen S/MIME.

3.5 Aspectos Sociales del email y seguridad

Un diseño socio-técnico compartiría los derechos de la comunicación asegurando que:

- Una conversación por "email" requeriría consentimiento mutuo
- Los usuarios tienen el derecho a ser dejados aparte y podrían rechazar el conversar.
- Cualquiera puede solicitar una conversación, dando pequeñas peticiones que identifican al emisor y el propósito.
- Los usuarios conversan pidiendo el "turno de palabra" sin más instrucciones. La conversación puede ser abandonada por cualquier participante en cualquier momento.

3.5.1 SPAM y mecanismos de seguridad

SPAM: Correo no deseado enviado "indiscriminadamente" con distintos objetivos

Existen distintas aproximaciones para atajar el SPAM, como SMTP-AUTH (RFC 4954). Inalcanzable por extensa. Microsoft ha promovido su propietario Secure Password Authentication (SPA) basado en SMTP-AUTH con escaso éxito.

Modificar intensivamente SMTP, o reemplazarlo completamente no es práctico ni viable.

Existen alternativas para aceptar correo electrónico de servidores autenticados → **DNSBLs (DNS Black Lists)**: se usa como lista de sitios autorizados a enviar email, y para determinar la reputación de esos sitios

Sender Policy Framework: protección contra la falsificación de direcciones en el envío de e-mail. Identifica, a través de los registros de nombres de dominio (DNS) a los servidores de correo SMTP autorizados para el transporte de los mensajes. **Autenticación basada en el camino recorrido por el correo**

Sender Policy Framework consta de 5 pasos:

- 1) El emisor envía un mensaje que es recibido por el Servidor de correo entrante
- 2) El emisor de correo entrante invoca mediante SPF Lookup al servidor DNS
- 3) El servidor DNS recoge la información del Registro SPF y se la devuelve al servidor de correo entrante.
- 4) Si el proceso de autenticación es satisfactorio se pasa a verificar la reputación
- 5) Se clasifica el correo recibido como "válido", basura, se pone en cuarentena o se bloquea

DomainKeys Identified Mail – DKIM (Correo Identificado mediante claves de Dominio) fusión de:

- **DomainKeys**
- **Identified Internet Mail.**

RFC5585: DKIM Service Overview: Es un mecanismo de autenticación de correo electrónico que permite a una organización responsabilizarse del envío de un mensaje, de manera que éste pueda ser validado por un destinatario a través de autenticación criptográfica. Dicha organización puede ser una fuente directa del mensaje, como el autor, el servidor encargado de gestionar el correo de ese dominio, o un servidor intermedio situado en el tránsito que recorre dicho correo, como por ejemplo un servicio independiente que provee recursos de correo al servidor que gestiona el dominio principal.

DMARC Domain-based Message Authentication, Reporting and Conformance

Autenticación, Reporte y Conformidad de mensajes basado en dominios (DMARC) es un estándar de Internet que permite a los remitentes y receptores comunicar la información de autenticación de correo electrónico para frustrar el phishing

Amplía los dos mecanismos anteriormente descritos (**Sender Policy Framework - SPF**) y el "Correo identificado por claves de dominio" (**DomainKeys Identified Mail - DKIM**),

A alto nivel, DMARC ha sido diseñado para satisfacer los siguientes requisitos:

- ✓ Minimizar falsos positivos.
- ✓ Proveer de informes de autenticación robusta
- ✓ Confirmar la política de emisor a los receptores
- ✓ Reducir la recepción **exitosa** de phishing
- ✓ Trabajar a gran escala en Internet
- ✓ Minimizar la complejidad.

Author Domain Signing Practices (ADSP)

Extensión opcional del esquema DKIM de autenticación de email, donde un dominio puede publicar las prácticas que adopta cuando delega el correo en representación de autores asociados. Desde Noviembre de 2013 está en desuso

Formato de Informe de fallo en la Autenticación (Authentication Failure Reporting Format - AFRF)

Nueva extensión del sub-tipo de informes para el Formato de Informes de abuso (ARF) definida por la RFC 5965. Permite la retransmisión de datos forenses con respecto a un error de autenticación compatible con el reporte de SPF y / o fallos DKIM

Challenge-response spam filtering – Channel email

Sistemas de Desafío/Respuesta (Challenge-response systems o C/R). Para combatir el spam requieren que los emisores desconocidos pasen varios tests antes de que sus mensajes sean entregados.

Channel e-mail es multipaso:

- 1) Solicitud de permiso del canal: Petición de conversación (A hacia B)
- 2) Permiso de Canal: Respuesta positiva (de B a A)

- 3) Intercambio de mensajes: Intercambio mutuo de mensajes de conversación
- 4) Cierre del Canal: Cada parte cierra el canal

El control del canal no se realiza por mensajes (tedioso) sino por el canal entero, incluyendo futuros mensajes del mismo origen.

"Channel e-mail clasifica los canales en:

- a) Canal abierto: Siempre se acepta
- b) Canal cerrado: siempre se rechaza
- c) Sin clasificar: Pregúntame cada vez

Por defecto sería "Aceptar todos",

De manera similar a como se protege mediante las listas negras ("Blacklist") un ISP, "Channel e-mail" proporciona a los usuarios sus propias listas para aceptar y rechazar emails.

3.5.2 Phishing, variantes y mecanismos de seguridad

PHISING: Ataque por email que solicitará algún tipo de información (obtención de claves de un sistema de banca electrónica, etc.) del destinatario que pueda utilizar para cometer algún tipo de fraude (financiero, con la Administración Pública, etc.). Este tipo de amenazas reciben en inglés el nombre de "phishing" y también son aplicables a la suplantación de páginas web. Existen distintas variantes evolucionadas sofisticadas del Phising:

- ✓ **Spear phishing:** Ataque en el que previamente se ha obtenido información del atacado para ganarse su confianza y se envían correos electrónicos personalizados.
- ✓ **Clone phishing:** Se reutiliza un correo legítimo y usado anteriormente para clonarlo y que parezca lo más parecido al original. El enlace o anexo que contenga el mensaje original se reemplaza por el correspondiente malicioso.
- ✓ **Whaling:** El ataque de phishing se dirige a un alto ejecutivo o perfiles altos empresariales.
- ✓ **Filter evasión:** Se utilizan imágenes en lugar de texto plano para evitar los filtros anti-phishing. Se combate mediante técnicas de OCR
- ✓ **Website Forgery:** Una vez visitado un sitio web "falso" existen muchas amenazas que afectan al comportamiento del navegador del usuario (alteración de la barra de navegación, etc...)
- ✓ **Phlashing:** El sitio web al que se redirige un ataque de phishing se ha implementado usando tecnología Flash para evitar los filtros anti-spam.

4 Algunos Productos

4.1 Productos de Correo Electrónico

- Freeware: Sendmail, Qmail, Mozilla Thunderbird.
- **Oracle Communications Messaging Server** -Antiguo SunONE Messenger Server
- Microsoft Exchange Server (Outlook), y Lotus Notes / Domino

Los sistemas propietarios (MS Exchange, LotusNotes, etc) y los sistemas de correo web (como Hotmail, Gmail y Yahoo! Mail) utilizan sus propios protocolos no estándar para acceder a las cuentas de correo en sus propios servidores de correo.

Todos usan SMTP cuando envían o reciben correo electrónico desde fuera de sus propios sistemas, por interoperabilidad.

5 Enlaces

Copias de los RFCs

<http://www.rfc-editor.org>

S/MIME Mail Security (smime)

<http://www.ietf.org/html.charters/smime-charter.html>